DOCUMENTO DE CÁTEDRA N° 9

TEMA: SCADA — ARQUITECTURA DE LA SUPERVISIÓN INDUSTRIAL

Apertura: El día que un cursor mató el suministro de agua de una ciudad

El 5 de febrero de 2021, un operador de la planta de tratamiento de agua de Oldsmar, Florida, observó cómo el cursor de su pantalla se movía solo. Alguien, desde una ubicación desconocida, había tomado el control remoto del sistema SCADA de la planta. En cuestión de minutos, el intruso navegó hacia la pantalla que controlaba el sistema de dosificación de hidróxido de sodio — la lejía que se añade al agua para ajustar su pH — y aumentó la concentración programada de 111 partes por millón a 11.100 partes por millón. Un factor de 100.

El operador, que observaba su pantalla en tiempo real, tomó el control manual y revirtió el cambio. La ciudad de 15.000 habitantes nunca supo que estuvo a horas de recibir agua con una concentración tóxica de lejía.

La investigación reveló que el sistema SCADA de la planta era accesible públicamente a través de TeamViewer con credenciales compartidas entre empleados, y que el sistema operativo de las HMIs era Windows 7 sin soporte. Pero más allá de las vulnerabilidades técnicas específicas, el caso Oldsmar ilustra la premisa central de esta unidad: el sistema SCADA es la infraestructura que hace posible controlar procesos físicos críticos desde una pantalla. Comprenderlo es el primer requisito para defenderlo.

Ubicación en el Programa: Este Documento N° 9 abre la Unidad 3 con el análisis de la arquitectura SCADA completa: desde la función de supervisión hasta los componentes individuales del sistema (MTU, servidor de comunicaciones, bases de datos de tiempo real). Los documentos N° 5 (PLC), N° 7 (RTU) y N° 8 (HMI) son prerrequisitos conceptuales: el PLC ejecuta la lógica, la RTU extiende el control al campo, la HMI presenta los datos al operador, y el SCADA integra todo en un sistema de supervisión centralizado. El Documento N° 11 complementará este con el servidor historian y las comunicaciones en profundidad.

Objetivos de Aprendizaje

Al finalizar la lectura de este documento, el alumno será capaz de:

- Definir SCADA y describir su función en la jerarquía de control industrial, diferenciándolo de los niveles inferiores (PLC, RTU, HMI) ya estudiados.
- Identificar y describir los componentes arquitectónicos de un sistema SCADA: servidor MTU, servidores de comunicación, bases de datos de tiempo real y la consola de operador.
- Explicar el flujo de información desde el campo (sensores, actuadores) hasta la sala de control a través de los distintos niveles de la arquitectura Purdue.
- Analizar las vulnerabilidades de seguridad que resultan de cada decisión de diseño arquitectónico del sistema SCADA.
- Relacionar el caso Oldsmar con las debilidades específicas de la arquitectura SCADA y proponer contramedidas de diseño que habrían mitigado el riesgo.

1. Definición y Función del SCADA

SCADA (Supervisory Control and Data Acquisition — Supervisión, Control y Adquisición de Datos) es un sistema de software y hardware cuya función es monitorear y controlar en tiempo real procesos físicos distribuidos geográficamente, centralizando la información en un punto único de supervisión y permitiendo la intervención remota sobre los procesos sin necesidad de presencia física en cada punto de control.

La palabra clave en la definición es "supervisory": el SCADA no controla directamente los actuadores. El control en lazo cerrado (encender una bomba, abrir una válvula, ajustar la velocidad de un motor) es ejecutado por los PLCs y RTUs del nivel inferior. El SCADA supervisa ese control: recolecta los datos del estado del sistema, los presenta al operador de forma comprensible, registra la historia del proceso, gestiona las alarmas y — cuando el operador lo decide — transmite comandos hacia los dispositivos de campo a través de los controladores.

Esta distinción entre control (PLC/RTU) y supervisión (SCADA) es fundamental para la Ciberdefensa porque determina el impacto de un ataque en cada nivel:

- Un ataque a un PLC produce efectos inmediatos y físicamente directos en el proceso (apertura de una válvula, detención de una bomba).
- Un ataque al SCADA produce efectos mediados: el adversario puede emitir comandos a través del SCADA hacia los PLCs, puede falsificar los datos que el operador ve en su pantalla, puede eliminar el registro histórico del proceso, o puede simplemente privar al operador de visibilidad sobre el sistema en el momento crítico.

El caso Oldsmar demostró que un adversario con acceso al SCADA tiene en sus manos un tablero de control sobre la infraestructura física que lo hace equivalente a un operador autorizado — con la diferencia de que no tiene los conocimientos del proceso ni la responsabilidad legal que actúa como freno en un operador real.

2. La Jerarquía de Control: del Campo a la Sala de Mandos

Para comprender el SCADA es necesario situarlo en la arquitectura completa del control industrial. La representación más utilizada internacionalmente es el Modelo de Referencia Purdue (también conocido como PERA — Purdue Enterprise Reference Architecture), definido originalmente por Theodore Williams en la década de 1990 y adoptado como referencia por el estándar ISA/IEC 62443.

El modelo Purdue organiza los sistemas de control industrial en cinco niveles, cada uno con funciones, dispositivos y protocolos específicos:

Nivel Purdue	Denominación	Función principal	Dispositivos típicos	Relevancia para Ciberdefensa
Nivel 0	Campo	Interacción física con el proceso: medición y actuación.	Sensores, transmisores, actuadores, válvulas, motores.	Daño físico directo si se compromete. Sin autenticación en la mayoría de los dispositivos.
Nivel 1	Control básico	Ejecución del lazo de control automático.	PLCs, DCS locales, variadores de frecuencia.	Lógica modificable. Ciclo de scan atacable. Estudiado en U2 (Docs 5–7).
Nivel 2	Supervisión	Monitoreo del proceso. Interfaz con el operador.	HMI, consolas SCADA, alarmas, tendencias.	Vector de falsificación de estado y alarm flooding (Doc 8). SCADA reside aquí.

Nivel Purdue	Denominación	Función principal	Dispositivos típicos	Relevancia para Ciberdefensa
Nivel 3	Gestión de producción	Planificación de la producción. Informes de planta.	MES (Manufacturing Execution Systems), servidores historian.	Punto de convergencia IT/OT. Primer nivel que típicamente conecta con la red IT corporativa.
Nivel 4-5	IT corporativa / Internet	Sistemas de negocio: ERP, correo, reportes directivos.	Servidores IT, usuarios corporativos.	Origen de la mayoría de los vectores de entrada a la red OT. Tema central de la Unidad 4.

El SCADA opera principalmente en los Niveles 2 y 3 del modelo Purdue. Es el sistema que integra la información del campo (Nivel 0-1), la presenta al operador (Nivel 2) y la expone para los sistemas de gestión (Nivel 3). Esta posición de bisagra entre el mundo físico del proceso y el mundo digital de la gestión empresarial es exactamente lo que hace al SCADA tan crítico desde la perspectiva de la Ciberdefensa.

⚠ Nota de Ciberdefensa — El puente como punto de ruptura: El SCADA actúa como puente entre el mundo OT (donde los errores matan equipos o personas) y el mundo IT (donde los errores se parchean). Todo adversario que ingresa por la red IT corporativa y busca afectar infraestructura física tiene al SCADA como su objetivo intermedio: comprometerlo equivale a tener acceso supervisado a toda la instalación.

3. El Servidor MTU: El Cerebro del Sistema SCADA

El componente central de toda arquitectura SCADA es el servidor MTU (Master Terminal Unit o Master Telemetry Unit). En la terminología más moderna suele denominarse simplemente "servidor SCADA" o "servidor de supervisión", pero el acrónimo MTU sigue siendo ampliamente utilizado en la documentación técnica y en el examen de certificaciones.

El MTU es el servidor que ejecuta el software de supervisión y que gestiona todas las comunicaciones con los dispositivos de campo (PLCs, RTUs). Sus funciones principales son:

Función del MTU	Descripción técnica	Vulnerabilidad asociada
Polling de datos	El MTU interroga periódicamente a cada RTU y PLC en su red para recolectar el valor actual de las variables de proceso. En protocolos como Modbus RTU, el MTU es el master y los dispositivos de campo son los slaves — solo responden cuando son consultados.	Sin autenticación en Modbus: cualquier dispositivo en la red puede responder al MTU con datos falsos.
Procesamiento de alarmas	El MTU compara los valores recibidos con los umbrales configurados y genera alertas cuando se detectan condiciones fuera de rango. Las alarmas se priorizan, registran y envían a las consolas de operador.	Manipulación de umbrales desde acceso no autorizado: alarmas críticas pueden desactivarse silenciosamente.
Escritura en base de datos de tiempo real	Los valores recolectados se almacenan en una base de datos de tiempo real (RTDB — Real-Time Database) que alimenta las HMIs. La RTDB es la fuente de verdad que ven los operadores en sus sinópticos.	Si la RTDB se compromete, el operador ve datos falsos aunque el proceso físico esté en anomalía.

Función del MTU	Descripción técnica	Vulnerabilidad asociada
Transmisión de comandos	Cuando el operador ejecuta una acción en la HMI (abrir una válvula, cambiar un setpoint), el MTU traduce esa acción en un comando de protocolo industrial y lo transmite al dispositivo de campo correspondiente.	Acceso no autorizado al MTU equivale a capacidad de comando sobre toda la instalación.
Gestión de la redundancia	Los sistemas SCADA críticos implementan pares de MTUs en configuración activo-pasivo. Si el MTU primario falla, el secundario asume la operación sin interrupción del servicio.	Si el mecanismo de failover no tiene autenticación propia, un adversario puede forzar el failover hacia un MTU que controla.

4. Componentes de la Arquitectura SCADA

Un sistema SCADA completo es más que el servidor MTU. La arquitectura típica de producción incluye los siguientes componentes, cada uno con su función específica y su perfil de riesgo:

4.1. Servidor de Comunicaciones (Front-End Processor — FEP)

En instalaciones de mediana y gran escala, el MTU no gestiona directamente las comunicaciones con los dispositivos de campo: delega esa función a uno o varios servidores de comunicaciones o FEPs (Front-End Processors). El FEP es el componente que mantiene abiertos los canales de comunicación con las RTUs remotas, ejecuta el polling, y transmite los datos al MTU a través de la red OT interna.

Esta separación de funciones tiene ventajas operativas (el MTU puede concentrarse en el procesamiento de datos sin la carga del polling) y de seguridad (el FEP actúa como primer punto de contacto con la red de campo, pudiendo filtrar comunicaciones anómalas antes de que lleguen al MTU). Sin embargo, también introduce un nodo adicional que debe ser protegido y monitoreado.

4.2. Servidor de Aplicaciones

El servidor de aplicaciones ejecuta las interfaces de usuario (HMIs), los sistemas de alarmas, los generadores de reportes y los módulos de cálculo avanzado (como el balance de energía en una red eléctrica, o el cálculo de eficiencia en una planta de producción). En instalaciones pequeñas, el servidor de aplicaciones y el MTU pueden coexistir en la misma máquina física; en instalaciones críticas de alta disponibilidad se separan para que la carga computacional de las HMIs no afecte el rendimiento del polling.

4.3. Base de Datos de Tiempo Real (RTDB)

La RTDB (Real-Time Database) es el corazón de datos del sistema SCADA. Almacena el valor actual de cada variable de proceso (llamada "tag" en la jerga SCADA) con una latencia de actualización típica de milisegundos a segundos, dependiendo del protocolo y la configuración del polling. Es la fuente que alimenta los sinópticos de la HMI y el sistema de alarmas.

La RTDB es diferente de una base de datos relacional convencional: no optimiza para transacciones complejas sino para escritura y lectura de altísima frecuencia con marca de tiempo. En el mercado existen soluciones propietarias ampliamente utilizadas como OSIsoft PI (ahora AVEVA PI System), Wonderware InMemory Database o GE Proficy Historian, y alternativas open source como InfluxDB o TimescaleDB.

⚠ Nota de Ciberdefensa — La RTDB como objetivo de falsificación: Como se analizó en el Documento N° 8 para el caso Ucrania 2015, la RTDB es el objetivo de falsificación de estado por excelencia. Si un adversario puede escribir en la RTDB valores normales falsos mientras el proceso real está en anomalía, el operador tomará decisiones sobre una realidad fabricada. La RTDB debe

tener control de acceso de escritura estricto, con acceso permitido exclusivamente al servidor MTU/FEP autenticado.

5. Topologías de Comunicación SCADA

La forma en que el servidor MTU se comunica con las RTUs y PLCs en el campo define la topología de comunicación del sistema SCADA. Esta decisión arquitectónica tiene implicaciones profundas tanto para la disponibilidad del sistema como para su superficie de ataque.

Topología	Descripción	Ventaja operativa	Riesgo de seguridad
Punto a punto	El MTU mantiene un enlace dedicado con cada RTU. Cada dispositivo tiene su propio canal de comunicación.	Máxima disponibilidad: el fallo de un enlace no afecta a los demás. Latencia mínima.	Alta superficie de ataque: muchos canales que monitorear. Costoso de asegurar individualmente.
Multipunto (polling maestro)	El MTU comparte un único canal de comunicación con múltiples RTUs. Interroga a cada una secuencialmente.	Económico. Usado en sistemas con ancho de banda limitado (radio, líneas serie).	Si el canal es comprometido, todos los dispositivos en él quedan expuestos. El polling sin autenticación permite inyección de respuestas falsas.
Estrella (red IP)	Los dispositivos de campo se conectan al MTU a través de una red IP (Ethernet, fibra). Es la topología predominante en instalaciones modernas convergidas con IT.	Alta velocidad y flexibilidad. Permite integración con protocolos IP modernos como Modbus TCP o DNP3 sobre TCP.	Exposición a todos los vectores de ataque IP: escaneo de puertos, ataques de red, pivoting desde la red IT corporativa.
Malla (mesh redundante)	Cada dispositivo de campo tiene múltiples rutas al MTU a través de nodos intermedios. Topología típica en redes eléctricas de transmisión.	Máxima resiliencia ante fallos de infraestructura. Sin punto único de fallo.	La complejidad dificulta el monitoreo de seguridad. Más nodos implica más superficie de ataque.

5.1. Medios de Comunicación

Los medios por los cuales el MTU se comunica con las RTUs en el campo han evolucionado significativamente a lo largo de la historia del SCADA, y muchos sistemas en operación coexisten con legados de múltiples generaciones tecnológicas:

- Líneas serie (RS-232, RS-485): medio de comunicación original de muchos sistemas SCADA. Sin capacidad nativa de cifrado. Aún presentes en instalaciones antiguas o de larga data.
- Radio (VHF/UHF, microondas): estándar en sistemas distribuidos geográficamente como oleoductos y redes de agua rurales. La señal de radio puede interceptarse con equipamiento accesible.
- Redes IP privadas (fibra, Ethernet industrial): el medio predominante en instalaciones modernas. Heredan la velocidad y flexibilidad de IT junto con todos sus vectores de ataque.

- Redes celulares (4G/5G): creciente adopción para RTUs en ubicaciones sin infraestructura de red propia. Introduce dependencia en infraestructura de terceros no controlada por el operador.
- Redes satelitales: opción de último recurso para instalaciones en zonas remotas extremas. Latencia elevada.

6. Vulnerabilidades Arquitectónicas del Sistema SCADA

Las vulnerabilidades del SCADA no son solo técnicas (una falla en un componente) sino arquitectónicas: emergen de las decisiones de diseño que se tomaron décadas atrás, cuando la seguridad no era una prioridad porque los sistemas SCADA estaban físicamente aislados. La convergencia IT/OT ha expuesto esas decisiones de diseño a un contexto de amenazas para el que no fueron concebidas.

Vulnerabilidad arquitectónica	Descripción	Ejemplo documentado	Contramedida de diseño
Diseño para disponibilidad, no para seguridad	El protocolo Modbus no tiene autenticación. El MTU acepta como válida cualquier respuesta que llegue en el formato correcto. No fue diseñado para un entorno hostil.	Oldsmar (2021): acceso sin MFA al sistema SCADA a través de TeamViewer.	Implementar autenticación en la capa de aplicación (DNP3 SAv5). Agregar un sistema de detección de anomalías que identifique valores fuera del rango de operación normal.
Ciclo de vida extendido sin parches	Los sistemas SCADA en infraestructura crítica pueden operar por 20-30 años. Los sistemas operativos de los servidores MTU suelen ser versiones legacy sin soporte activo de seguridad.	Oldsmar (2021): Windows 7 sin soporte en las HMIs.	Application whitelisting (Lista blanca) como alternativa al antivirus. Segmentación de red para aislar el SCADA del entorno no seguro.
Acceso remoto sin control	Las herramientas de acceso remoto (TeamViewer, VNC, RDP) son necesarias para el soporte de mantenimiento del fabricante. Con frecuencia se instalan sin control de acceso robusto.	Oldsmar (2021): credenciales TeamViewer compartidas entre empleados. Sin MFA.	Acceso remoto exclusivamente a través de soluciones de PAM (Privileged Access Management) con grabación de sesión, MFA y tiempo de acceso limitado.
Convergencia sin segmentación	La integración del SCADA con sistemas IT corporativos (para reportes, ERP) frecuentemente se implementa con conectividad directa entre ambas redes, sin DMZ ni firewall industrial.	Industroyer (2015): acceso a la red OT de subestaciones eléctricas a través de la red IT corporativa.	Arquitectura con DMZ OT entre red IT y red SCADA. Comunicación unidireccional (data diode) para el flujo de datos del historian hacia IT.

7. Arquitectura SCADA de Referencia: El Modelo con DMZ OT

La arquitectura de referencia recomendada por NIST SP 800-82 y por el estándar ISA/IEC 62443 para sistemas SCADA que deben interoperar con redes IT corporativas es la arquitectura con DMZ OT (Zona Desmilitarizada para Tecnología Operativa). El objetivo de esta arquitectura es permitir el flujo de datos del proceso hacia los sistemas corporativos (reporting, ERP, historian empresarial) sin crear un camino directo entre la red IT y la red OT.

Los componentes clave de esta arquitectura son:

- Firewall industrial de doble etapa: un firewall entre la red IT y la DMZ OT, y otro entre la DMZ OT y la red OT. Ningún flujo atraviesa ambos firewalls sin pasar por la DMZ.
- Servidor historian en la DMZ OT: el historian de planta en la red OT replica sus datos en un servidor historian espejo ubicado en la DMZ. Los sistemas IT consultan la copia en la DMZ, no el historian original.
- Servidor de salto (Jump Server) en la DMZ OT: todo acceso remoto a la red OT pasa por el servidor de salto en la DMZ, que autentica al usuario, registra la sesión y establece el canal hacia el destino en la red OT. Nunca hay acceso directo desde IT a OT.
- Data Diode (opcional, máxima seguridad): en instalaciones de máxima criticidad, la comunicación entre la DMZ OT y la red OT puede implementarse con un data diode — un dispositivo de hardware que garantiza que los datos solo fluyen en una dirección (OT → DMZ), haciendo físicamente imposible que un comando llegue desde la DMZ hacia la red OT.

8. Actividades de Verificación y Análisis

1. El operador de una pequeña planta de tratamiento de agua propone conectar el servidor MTU de su sistema SCADA directamente a la red Wi-Fi corporativa para poder monitorear el proceso desde su tablet durante los turnos de guardia. Identifique los tres riesgos de seguridad más críticos que esta decisión introduce. Proponga una arquitectura alternativa que le permita al operador obtener visibilidad remota del proceso con un perfil de riesgo aceptable.
2. Compare el impacto potencial de un ataque al PLC que controla una bomba con un ataque al servidor MTU del SCADA que supervisa esa misma bomba. ¿En qué difieren los efectos en términos de escala, persistencia y detección? ¿Cuál de los dos ataques es más difícil de atribuir? Justifique.
3. Analice el caso Oldsmar desde la perspectiva de las vulnerabilidades arquitectónicas descritas en la Sección 6. ¿Cuántas de las cuatro vulnerabilidades identificadas en la tabla estaban presentes en el sistema atacado? ¿Qué nivel del modelo Purdue fue comprometido? ¿El ataque afectó el Nivel 0 (campo) directamente o lo hizo a través del Nivel 2 (supervisión)?
4. Análisis de Caso Integrador: Un sistema SCADA de gestión de una red de distribución eléctrica regional utiliza topología multipunto con radio VHF para comunicarse con 45 RTUs distribuidas en un área de 300 km². El operador del sistema recibe una propuesta comercial para migrar las comunicaciones a 4G LTE, lo que reduciría los costos operativos un 40%. Identifique dos ventajas de seguridad y dos nuevas vulnerabilidades que introduce la migración a 4G. ¿Qué contramedidas arquitectónicas permitirían implementar la migración preservando el perfil de riesgo del sistema original?

9. Glosario Mínimo

- **Data Diode:** Dispositivo de hardware que garantiza comunicación unidireccional entre dos redes. Los datos pueden fluir solo en la dirección física predeterminada, haciendo imposible

por diseño que un comando viaje en sentido contrario. Solución de máxima seguridad para la interfaz entre red OT y DMZ.

- **DMZ OT (Zona Desmilitarizada para OT):** Segmento de red intermedio entre la red IT corporativa y la red OT industrial, protegido por firewalls en ambos lados. Los servidores en la DMZ sirven como intermediarios controlados para el intercambio de datos entre ambas redes, sin crear conectividad directa.
- **FEP (Front-End Processor):** Servidor de comunicaciones que gestiona el polling de los dispositivos de campo (RTUs, PLCs) y entrega los datos al servidor MTU principal. Permite escalar el sistema SCADA sin sobrecargar el MTU con la gestión de comunicaciones.
- **MTU (Master Terminal Unit):** Servidor central del sistema SCADA. Gestiona el polling de datos, procesa alarmas, escribe en la base de datos de tiempo real y transmite comandos hacia los dispositivos de campo a solicitud del operador. Es el cerebro de la arquitectura de supervisión.
- **Modelo Purdue (PERA):** Arquitectura de referencia para redes de control industrial, organizada en 5 niveles (0 a 4/5) que van desde el campo físico hasta los sistemas de IT corporativa. Adoptado por ISA/IEC 62443 como modelo de referencia para la segmentación de redes OT.
- **Polling:** Mecanismo de comunicación en el que el master (MTU/FEP) interroga periódicamente a cada slave (RTU/PLC) para obtener el valor actualizado de las variables de proceso. En protocolos sin autenticación como Modbus RTU, el master acepta como válida cualquier respuesta que cumpla el formato del protocolo.
- **RTDB (Real-Time Database):** Base de datos de tiempo real que almacena el valor actual de cada variable (tag) del proceso con alta frecuencia de actualización. Es la fuente de datos que alimenta las HMIs y el sistema de alarmas. Su compromiso permite falsificar el estado del proceso que el operador observa.
- **SCADA (Supervisory Control and Data Acquisition):** Sistema de supervisión, control y adquisición de datos que centraliza el monitoreo de procesos físicos distribuidos geográficamente, recolectando datos de los dispositivos de campo (a través de PLCs y RTUs), presentándolos al operador y permitiendo la intervención remota sobre el proceso.

10. Referencias Bibliográficas

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security: Securing Critical Infrastructure Networks for Smart Grid, SCADA, and Other Industrial Control Systems (2da ed.). Waltham, MA: Syngress. (Capítulo 2: Industrial Control Systems; Capítulo 3: Industrial Protocols — sección SCADA).

Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., & Lightman, S. (2023). Guide to Operational Technology (OT) Security (NIST Special Publication 800-82 Revision 3). Gaithersburg, MD: NIST. (Sección 2.5: Network Protocols; Apéndice C: Vulnerabilidades arquitectónicas).

Williams, T. J. (1994). The Purdue Enterprise Reference Architecture. Computers in Industry, 24(2-3), 141–158.

Assante, M., & Lee, R. (2015). The Industrial Control System Cyber Kill Chain. SANS ICS.

Cátedra Tecnología Operativa (2026). Ficha de Cátedra N° 2: Arquitecturas en Sectores Críticos (BMS, Transporte y Accesos). FADENA.